



**HOGESCHOOL
UTRECHT**



BEVINDINGEN ENUMERATION

Disclaimer:

Deze documentatie is uitsluitend bedoeld voor educatieve doeleinden. Screenshots en informatie over hackingtools zijn opgenomen om bewustwording en kennis over cybersecurity te vergroten. Illegaal gebruik wordt niet goedgekeurd of aangemoedigd. Gebruik deze informatie alleen op een legale en ethische manier.



Index

• Samenwerking	4
• Inleiding	4
• Ransomware	4-5
◦ De Geschiedenis van Ransomware	
■ De eerste ransomware – AIDS Trojan (1989)	
■ Opkomst van moderne ransomware (2000-2010)	
■ Explosieve groei – CryptoLocker en WannaCry (2013-2017)	
■ Ransomware als businessmodel (2018-heden)	
◦ Hoe werkt ransomware?	6-7
◦ Verdediging tegen ransomware volgens PTES	7-9
■ Samengevat	
◦ Ransomware en het CIA-triad model	9-10
◦ Conclusie	10
• Man-in-the-Middle-aanvallen	11-15
◦ Oorsprong van het concept	
◦ Begin van digitale MitM-aanvallen – jaren '80 en '90	
◦ Opkomst van Wi-Fi en SSL – nieuwe kansen en bedreigingen	
◦ Geavanceerde MitM-aanvallen – jaren 2010 tot heden	

◦ Hoe werkt een Man-in-the-Middle-aanval? ◦ Een voorbeeld in het echt ◦ Verdediging tegen Man-in-the-Middle (MitM) volgens PTES ◦ Samengevat ◦ Man-in-the-Middle-aanval & het CIA-triad model ◦ Conclusie	
• Ethisch handelen in onze simulatie aanval	16
• Een visuele uitwerking van de verschillende stappen die zijn gezet om deze fase te doorlopen	17
• Vergelijking van methoden/tools die zijn gebruikt (phishing & voorbereiding)	18
• Aanvalsstappen gekoppeld aan het PTES-framework	19-22
◦ Conclusie	
• Algemeen Conclusie	23
• Bronnenlijst	23

Samenwerking

Dit rapport is ontwikkeld en wordt uitgevoerd door Ali Othman en Cailyn Huwae als onderdeel van een gezamenlijke opdracht. Samen vormen wij een team dat een gesimuleerde ransomware-aanval en Man-in-the-Middle (MITM) voorbereidt. Cailyn is verantwoordelijk voor Man-in-the-Middle (MITM), terwijl Ali zich richt op het uitvoeren van de ransomware-aanval.

Inleiding

In een steeds digitalere wereld vormen cyberaanvallen een groeiende bedreiging voor individuen, bedrijven en overheden. Deze aanvallen zijn gericht op het verstoren, beschadigen of verkrijgen van ongeautoriseerde toegang tot digitale systemen en gegevens. Cybercriminelen maken gebruik van uiteenlopende technieken om zwakke plekken in netwerken, software of menselijk gedrag uit te buiten. Het doel varieert van financiële winst tot spionage, sabotage of het verspreiden van desinformatie. Binnen het brede spectrum van cyberaanvallen vallen ransomware en man-in-the-middle aanvallen op door hun effectiviteit en impact.

Ransomware

Ransomware is een type kwaadaardige software (malware) dat bestanden op een systeem versleutelt, waardoor ze ontoegankelijk worden voor de gebruiker. Slachtoffers krijgen vervolgens een eis tot losgeld, meestal in cryptovaluta, in ruil voor een decryptiesleutel. Sommige aanvallers dreigen ook met het openbaar maken van gestolen gegevens (dubbele of zelfs drievoudige afpersing).

De Geschiedenis van Ransomware

De eerste ransomware – AIDS Trojan (1989)

De allereerste bekende ransomware-aanval vond plaats in 1989 en stond bekend als de AIDS Trojan, ook wel de PC Cyborg-virus genoemd. Deze werd verspreid via 5,25-inch diskettes die zogenaamd informatie bevatten over AIDS. De diskettes werden per post verzonden naar deelnemers van een wetenschappelijk congres. Na ongeveer 90 keer opstarten versleutelde het virus de bestandsnamen op de harde schijf en eiste het een betaling van \$189, die verstuurd moest worden naar een postbus in Panama. Hoewel primitief, legde deze aanval de basis voor latere vormen van ransomware.

Opkomst van moderne ransomware (2000–2010)

In de vroege jaren 2000 verschenen geavanceerdere varianten van ransomware, zoals Gpcode en Archiveus, die gebruik maakten van sterkere encryptie. Deze aanvallen verspreidden zich voornamelijk via e-mailbijlagen of geïnfecteerde websites. De schade bleef in deze periode relatief beperkt, maar de technieken werden steeds geavanceerder.

Explosieve groei – CryptoLocker en WannaCry (2013–2017)

Een grote ommekeer kwam in 2013 met de opkomst van CryptoLocker, een ransomware die gebruikmaakte van sterke RSA-encryptie en zich snel verspreidde via e-mail. Slachtoffers moesten losgeld betalen in Bitcoin, wat de anonimiteit van de daders vergemakkelijkte. In 2017 volgde de wereldwijde uitbraak van WannaCry, een aanval die gebruikmaakte van een lek in Windows dat eerder door de NSA werd ontdekt. Honderdduizenden systemen wereldwijd werden getroffen, waaronder ziekenhuizen, bedrijven en overheden.

Ransomware als businessmodel (2018–heden)

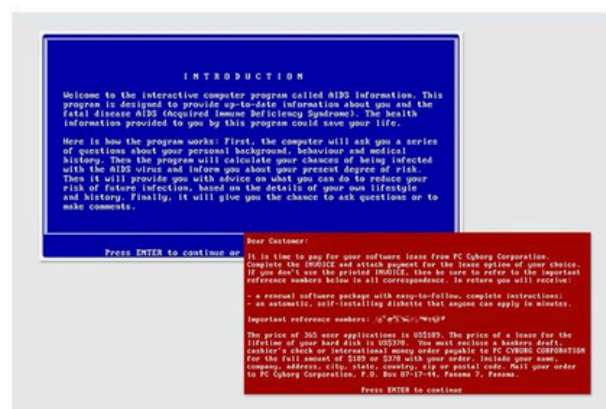
De afgelopen jaren is ransomware uitgegroeid tot een miljardenindustrie. Cybercriminelen gebruiken geavanceerde methoden en bieden zelfs Ransomware-as-a-Service (RaaS) aan, waarbij anderen hun ransomware kunnen huren om aanvallen uit te voeren. Bekende groepen zoals REvil, Conti en LockBit zijn verantwoordelijk voor talloze aanvallen wereldwijd.

Tegenwoordig richten ransomware-aanvallen zich steeds vaker op grote organisaties, ziekenhuizen, scholen en overheden. Vaak dreigen de aanvallers niet alleen met het versleutelen van data, maar ook met het publiceren van gevoelige informatie als er niet betaald wordt.

1989 – AIDS Trojan



Floppy Disk



Hoe werkt ransomware?

Ransomware werkt volgens een vrij simpel maar krachtig principe: het versleutelt (encrypt) of blokkeert je bestanden of hele systeem, en daarna eist het losgeld om alles weer toegankelijk te maken. Hieronder zie je hoe dat proces meestal verloopt:

1. Infectie

De ransomware komt op je computer terecht via bijvoorbeeld:

- Een valse e-mail met een kwaadaardige bijlage (zoals een Word- of PDF-bestand)
- Een link naar een besmette website
- Een download van een nep-programma of crack
- Via een zwakke plek in software (bijvoorbeeld verouderde Windows-versies)

2. Activering

Zodra je op de bijlage klikt of de link opent, wordt het virus actief:

- Het installeert zich op de achtergrond
- Het begint met het scannen van je systeem en netwerken
- Het zoekt naar belangrijke bestanden zoals documenten, foto's, spreadsheets, etc.

3. Versleuteling van bestanden

- De ransomware gebruikt sterke encryptie-algoritmes (zoals AES of RSA) om je bestanden onleesbaar te maken
- De bestandsnamen worden soms ook aangepast (bijv. document.docx wordt document.locked)
- Je krijgt geen toegang meer tot je eigen bestanden zonder de "sleutel"

4. Losgeldmelding (ransom note)

- Daarna verschijnt er een bericht op je scherm, bijvoorbeeld:
- "Je bestanden zijn versleuteld. Betaal \$500 in Bitcoin binnen 72 uur om ze terug te krijgen."
- Vaak zit er ook een timer bij om druk op je uit te oefenen

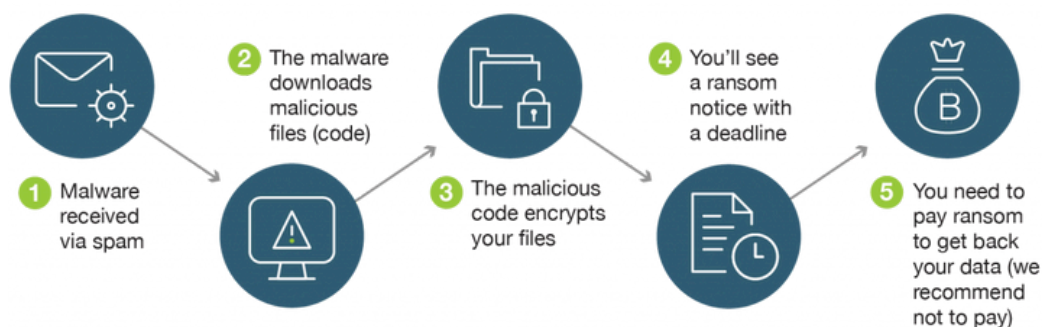
5. Betaling (niet aanbevolen!)

- Sommige slachtoffers betalen uit wanhoop, maar dat garandeert niet dat je de bestanden terugkrijgt
- Cybercriminelen zijn niet te vertrouwen, en soms vragen ze later nóg meer geld

6. Herstel of verlies

- Als je geluk hebt en een back-up hebt, kun je je systeem herstellen zonder te betalen
- Heb je geen back-up of hulp, dan zijn je bestanden vaak permanent verloren

How Ransomware Works



Verdediging tegen ransomware volgens PTES

1. Regelmatige back-ups (Post-Exploitation Mitigatie)

Zorg ervoor dat je regelmatig back-ups maakt van je belangrijke bestanden. Bewaar deze back-ups op een externe harde schijf of in de cloud, losgekoppeld van je computer. Zo kun je je gegevens herstellen zonder losgeld te betalen als je slachtoffer wordt van ransomware.

PTES-relevant: Minimaliseren van impact in de post-exploitation fase door snelle herstelmogelijkheden.

2. Betrouwbare antivirus- en endpointbescherming (Preventive Security Controls)

Gebruik up-to-date antivirussoftware die specifiek bescherming bieden tegen ransomwaregedrag.

PTES-relevant: Preventieve bescherming tijdens de exploitatie- en persistence-fase.

3. Software-updates en patchmanagement (System Hardening)

Implementeer een patchbeleid waarbij beveiligingsupdates voor besturingssystemen, browsers, plugins en andere software zo snel mogelijk worden geïnstalleerd.

PTES-relevant: Voorkomen van aanvallen tijdens de exploitation-fase.

4. Wees alert op phishing en verdachte e-mails (Awareness & Human Factor Defense)

Train om phishingmails en verdachte links te herkennen. E-mailfiltering en SPF/DKIM/DMARC kunnen helpen bij technische blokkering.

PTES-relevant: Verdediging tijdens de initial access-fase (social engineering).

5. Sterke, unieke wachtwoorden (Credential Security)

Voorkom credential stuffing en brute-force aanvallen door sterke wachtwoorden en een wachtwoordmanager in te zetten. Implementeer waar mogelijk lockout policies bij mislukte inlogpogingen.

PTES-relevant: Voorkomen van toegang via zwakke authenticatie in elke fase

6. Tweefactorauthenticatie (Authentication Hardening)

Voeg een extra beveiligingslaag toe via 2FA (zoals via sms of een authenticator-app). Zelfs bij gestolen inloggegevens wordt de kans op succesvolle toegang sterk verkleind.

PTES-relevant: Beperken van toegang tot systemen tijdens lateral movement of privilege escalation.

7. Geen onbekende USB-sticks gebruiken (Physical Security Awareness)

Fysieke toegang of externe apparaten kunnen als aanvalsvector dienen (bijv. via Rubber Ducky, HID spoofing). Beperk USB-gebruik en zorg dat autorun-functies zijn uitgeschakeld.

PTES-relevant: Bescherming tegen fysieke initial access en social engineering.

8. Blijf alert en op de hoogte (Continuous Improvement & Monitoring)
Volg nieuws over bedreigingen, volg incidenten op, en leer van pentests of simulaties.

PTES-relevant: Detectie in alle fases van de aanval (detection & response).

Samengevat

Deze maatregelen bestrijken meerdere PTES-fasen: van initial access (phishing) tot post-exploitation (encryptie/herstel). Door deze strategieën toe te passen, verklein je het aanvalsoppervlak en vergroot de digitale weerbaarheid tegen ransomware.

Ransomware en het CIA-triad model

Het CIA-triad model bestaat uit drie kernprincipes voor informatiebeveiliging:

- Confidentiality (Vertrouwelijkheid)
- Integrity (Integriteit)
- Availability (Beschikbaarheid)



Ransomware is een type aanval dat vaak alle drie deze principes in gevaar brengt.

1. Confidentiality – Vertrouwelijkheid

Bij moderne ransomware, vooral de zogeheten "double extortion" variant:

- Versleutelen de aanvallers niet alleen je bestanden...
- Maar stelen ze eerst de data voordat ze versleutelen

Ze dreigen ermee om je data openbaar te maken als je niet betaalt.

Dit betekent dat vertrouwelijke gegevens niet meer privé zijn.

2. Integrity – Integriteit

Ransomware wijzigt de inhoud van je bestanden door deze te versleutelen. Je data is dan:

- Niet meer toegankelijk
- Niet meer bruikbaar in originele vorm

De integriteit van je bestanden wordt dus geschonden, omdat je niet kunt vertrouwen op de juistheid of volledigheid ervan.

3. Availability – Beschikbaarheid

Dit is het meest directe gevolg van ransomware:

- Je krijgt geen toegang meer tot je systemen of bestanden
- Hele organisaties kunnen worden stilgelegd (bijv. ziekenhuizen, fabrieken, overheden)

De beschikbaarheid van data en systemen is volledig verstoord.

Conclusie

Ransomware blijft een evoluerende dreiging die aanzienlijke schade kan veroorzaken. Een combinatie van technologische maatregelen, bewustwording en proactieve strategieën is essentieel om organisaties te beschermen tegen deze vorm van cybercriminaliteit.

Man-in-the-Middle-aanvallen

Een Man-in-the-Middle-aanval (MitM) is een cyberaanval waarbij een aanvaller zich tussen twee communicerende partijen plaatst zonder dat zij dit doorhebben. De aanvaller kan zo communicatie afluisteren, aanpassen of vervalsen. Als voorbeeld: Persoon A moet voor zijn stage nog zijn rekeningnummer opsturen naar zijn stagebegeleider (Persoon B). Wanneer Persoon A alle benodigde gegevens in een mail heeft gezet, stuurt hij deze naar Persoon B toe. Voordat het bij Persoon B aankomt word het bericht eerst onderschept door de aanvaller (Persoon C). Persoon C zal het rekeningnummer vervangen met een ander rekeningnummer en deze doorsturen naar Persoon B waardoor het lijkt alsof er niks is veranderd en het bericht afkomstig is geweest van Persoon A.

Oorsprong van het concept

Het basisidee van een MitM-aanval is niet nieuw. Al vóór het digitale tijdperk werden berichten onderschept door tussenpersonen — bijvoorbeeld tijdens oorlogen of in diplomatieke communicatie. Denk aan het onderscheppen van brieven of het aftappen van telefoongesprekken. In feite was dit een analoge vorm van “man-in-the-middle”.

Begin van digitale MitM-aanvallen – jaren ‘80 en ‘90

Met de opkomst van computernetwerken in de jaren ‘80 en ‘90 begon de digitale variant van de MitM-aanval op te duiken. In deze periode waren veel netwerkprotocollen, zoals Telnet, FTP en zelfs het vroege HTTP, niet versleuteld. Daardoor konden aanvallers relatief eenvoudig netwerkverkeer onderscheppen en gevoelige informatie zoals wachtwoorden, gebruikersnamen en persoonlijke gegevens stelen.

Opkomst van Wi-Fi en SSL – nieuwe kansen en bedreigingen

Rond de jaren 2000 werd draadloos internet (Wi-Fi) populair, wat nieuwe kansen bood voor MitM-aanvallers. Een klassieke aanval was het opzetten van een nep-wifi-netwerk (“evil twin”) waarmee gebruikers onbewust verbinding maakten. Zodra ze verbonden waren, kon de aanvaller hun verkeer monitoren. Tegelijkertijd werd SSL (Secure Sockets Layer) geïntroduceerd om veilige communicatie via internet mogelijk te maken. Toch slaagden aanvallers erin om SSL te ondermijnen door valse certificaten, SSL-stripping en DNS-spoofing, waardoor ze alsnog toegang kregen tot versleuteld verkeer.

Geavanceerde MitM-aanvallen – jaren 2010 tot heden

In de afgelopen tien jaar zijn MitM-aanvallen complexer en geavanceerder geworden. Cybercriminelen gebruiken technieken zoals:

- ARP-spoofing om verkeer binnen lokale netwerken te onderscheppen
- DNS-kaping om verkeer om te leiden naar kwaadaardige websites
- Session hijacking waarbij inlogsessies worden overgenomen

Hoe werkt een Man-in-the-Middle-aanval?

1. Interceptie (onderscheppen)

De eerste stap is dat de aanvaller de communicatie weet af te luisteren. Dit gebeurt bijvoorbeeld via:

- Een nep-wifi-netwerk (zoals "Free_Wifi_Café")
- ARP-spoofing op een lokaal netwerk
- DNS-spoofing om verkeer om te leiden naar een kwaadaardige site

De gebruiker denkt dat hij rechtstreeks met een veilige website communiceert, maar eigenlijk gaat het verkeer via de aanvaller.

2. Decryptie of manipulatie

Als de data versleuteld is (bijv. via HTTPS), kan de aanvaller proberen:

- Het versleuteling om te leiden via SSL-stripping, waarbij HTTPS wordt teruggezet naar HTTP
- Een vals certificaat te gebruiken, zodat de gebruiker denkt dat de verbinding veilig is
- De communicatie tijdelijk te ontsleutelen, lezen, en weer versleutelen (bijv. via een proxy)

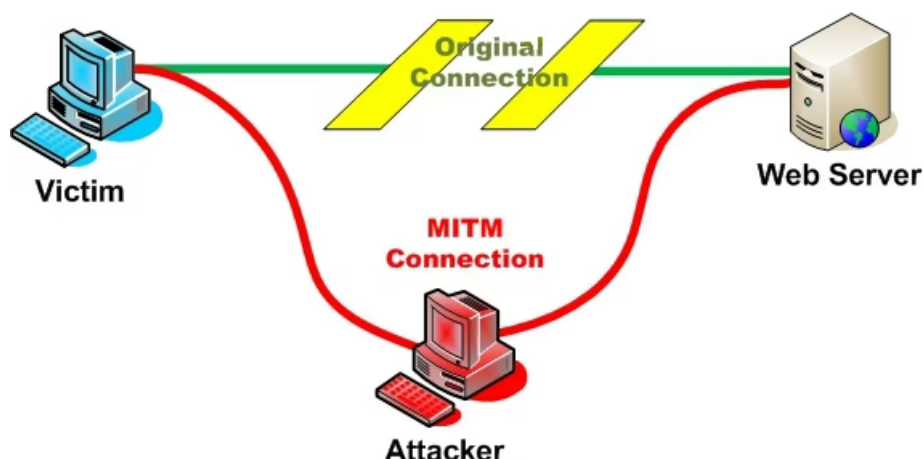
3. Informatie stelen of manipuleren

Zodra de aanvaller toegang heeft, kan hij:

- Wachtwoorden, creditcardgegevens of persoonlijke data stelen
- Berichten aanpassen (denk aan het wijzigen van rekeningnummers)
- Inloggen op sessies als jou, zonder dat je het merkt

Een voorbeeld in het echt

1. Jij verbindt met "Free_Wifi_Airport" (maar het is een nep-netwerk opgezet door de aanvaller)
2. Jij bezoekt je bankwebsite
3. De aanvaller stuurt jouw verzoek door naar de échte site en laat alles er normaal uitzien
4. Jij vult je gebruikersnaam en wachtwoord in
5. De aanvaller vangt dit op en kan zo inloggen als jou



Verdediging tegen Man-in-the-Middle (MitM) volgens PTES

1. Gebruik alleen beveiligde websites (HTTPS)

- PTES-fase: Initial Access / Data Collection
 - Controleer of websites beginnen met https:// en of er een slotje in de adresbalk staat
 - Klik nooit verder op een site die een beveiligingswaarschuwing geeft
 - HTTPS versleutelt je data zodat een aanvaller het niet zomaar kan lezen

2. Vermijd openbare wifi-netwerken

- PTES-fase: Initial Access
 - Openbare wifi (bijv. in cafés, luchthavens) is een hotspot voor MitM-aanvallen
 - Gebruik altijd een VPN als je toch openbare wifi moet gebruiken
 - Of gebruik je mobiele hotspot in plaats van open netwerken

3. Gebruik een VPN (Virtual Private Network)

- PTES-fase: Communication & Command Channels
 - Een VPN maakt een veilige, versleutelde tunnel tussen jouw apparaat en het internet
 - Hierdoor kunnen aanvallers je verkeer niet onderscheppen of manipuleren
 - Zeker aan te raden als je vaak reist of op openbare netwerken zit

4. Wees voorzichtig met e-mails en links

- PTES-fase: Reconnaissance / Initial Access
 - Klik nooit zomaar op verdachte links in e-mails of sms'jes
 - Check goed het e-mailadres van de afzender (phishing is vaak de eerste stap voor een MitM-aanval)

5. Gebruik 2-staps-verificatie (2FA)

- Zelfs als je wachtwoord wordt gestolen, kan de aanvaller niet inloggen zonder jouw tweede code
- Gebruik bij voorkeur een authenticator-app (zoals Google Authenticator) in plaats van SMS

6. Houd je software up-to-date

- PTES-fase: Credential Access / Privilege Escalation
 - Updates bevatten vaak beveiligingspatches die kwetsbaarheden dichten
 - Zorg dat je besturingssysteem, browser, antivirus en apps altijd up-to-date zijn

7. Gebruik van S/MIME-certificaten

- PTES-fase: Post-Exploitation / Reporting
 - S/MIME zorgt voor encryptie van e-mails zodat alleen de bedoelde ontvanger deze kan openen met een private key.
 - Elke verzonden e-mail bevat ook een digitale handtekening, die niet aangepast kan worden.
 - Hierdoor weet je zeker dat het bericht legitiem is en niet is gemanipuleerd.

8. Gebruik van Secure Email

- PTES-fase: Post-Exploitation / Reporting
 - Normaal e-mailverkeer geeft je als gebruiker geen controle over inbox en outbox. Secure Email plaatst alle berichten in een afgeschermd, versleutelde omgeving. Zo blijven jouw gegevens en die van collega's of klanten beschermd tegen onbevoegde toegang.
 - Al het mailverkeer binnen Secure Email is end-to-end versleuteld en beveiligd.

Samengevat

Binnen het PTES-framework helpen de volgende maatregelen bij het voorkomen van een Man-in-the-Middle-aanval:

- Initial Access: Gebruik alleen HTTPS, vermijd open wifi, en wees alert op phishing.
- Enumeration: Controleer certificaten en monitor verdachte netwerkactiviteit.
- Exploitation: Houd software up-to-date om bekende kwetsbaarheden te dichten.
- Credential Access: Gebruik sterke wachtwoorden en tweefactorauthenticatie.
- Persistence & Detection: Zet antivirus en firewalls in voor detectie van MitM-patronen.
- Post-Exploitation: Beperk schade door encryptie van gevoelige data en goede logging.

Man-in-the-Middle-aanval & het CIA-triad model

Het CIA-triad model bestaat uit drie kernprincipes voor informatiebeveiliging:

- Confidentiality (Vertrouwelijkheid)
- Integrity (Integriteit)
- Availability (Beschikbaarheid)

Een Man-in-the-Middle (MitM) aanval kan alle drie deze principes aantasten. Hieronder zie je hoe:

1. Confidentiality – Vertrouwelijkheid

Een MitM-aanvaller kan meelezen met gevoelige communicatie, zoals:

- Wachtwoorden
- Creditcardgegevens
- Persoonlijke of bedrijfsinformatie

Dit betekent dat de vertrouwelijkheid van de communicatie wordt geschonden.

2. Integrity – Integriteit

De aanvaller kan niet alleen data lezen, maar ook wijzigen zonder dat de verzender of ontvanger dit merkt. Denk aan:

- Het aanpassen van een IBAN-rekeningnummer in een e-mail
- Het wijzigen van inhoud in een chatgesprek

Hierdoor raakt de integriteit van de data aangetast.

3. Availability – Beschikbaarheid

Hoewel dit minder vaak voorkomt, kan een MitM-aanvaller ook:

- Verkeer blokkeren of omleiden, zodat de ontvanger het bericht nooit krijgt
- Systeemverkeer verstoren, waardoor websites of diensten tijdelijk onbruikbaar zijn

Zo kan ook de beschikbaarheid in gevaar komen.

Conclusie

Een Man-in-the-Middle-aanval is een gevaarlijke en vaak onzichtbare bedreiging waarbij een aanvaller zich tussen twee communicerende partijen plaatst om informatie te onderscheppen of te manipuleren. Door slim gebruik te maken van zwakke plekken in netwerken en beveiliging, kunnen aanvallers toegang krijgen tot gevoelige gegevens zoals wachtwoorden, bankgegevens of persoonlijke informatie.

Gelukkig kun je jezelf goed beschermen met simpele maatregelen zoals het vermijden van openbare wifi, het gebruik van een VPN, het controleren van HTTPS-verbindingen en het toepassen van tweestapsverificatie. Door bewust en waakzaam om te gaan met je digitale communicatie, verklein je de kans op een MitM-aanval aanzienlijk.

Ethisch handelen in onze simulatie aanval

Ethisch handelen is het allerbelangrijkste binnen ons team. Daarom hebben we de volgende stappen gevolgd om er zeker van te zijn dat onze gesimuleerde aanval volledig ethisch en verantwoord wordt uitgevoerd.

- Wij volgen strikt de gedragscode waar we als team gezamenlijk mee akkoord zijn gegaan. Dit zorgt ervoor dat al onze activiteiten op een ethische en verantwoordelijke manier worden uitgevoerd.
- In elk document waarin het gebruik van hackingtools wordt besproken, is een duidelijke disclaimer opgenomen.
- Het .exe-bestand in het ZIP-bestand bevat geen echte malware, maar een simulatie die enkel visuele meldingen toont en testbestanden versleutelt.
- Alle tests worden uitgevoerd in virtuele omgevingen of lokaal op persoonlijke apparaten.
- Alle stappen zijn gedocumenteerd conform onze Code of Conduct.

Een visuele uitwerking van de verschillende stappen die zijn gezet om deze fase te doorlopen

Proces Infographic



Stap 1 Toestemming Regelen

- DISC test maken.
- Elkaars standpunten en grenzen goed leren begrijpen
- Een gezamenlijke gedragscode maken

Stap 2 Informatie Verzamelen

- Begrijp de werking van ransomware, hoe het zich verspreidt, bestanden versleutelt en om losgeld vraagt.
- Onderzoek hoe een aanval communicatie kan onderscheppen of manipuleren tussen twee partijen.
- Verken mogelijke verdedigingsmaatregelen tegen deze aanvallen



Stap 3 Doel Bepalen

- Verdelen van de taken op basis van kennis en beschikbaarheid
- Duidelijke afspraken maken over wie wat doet

Stap 4 Tools Selecteren of maken

- Inventariseren welke tools nodig zijn voor de simulatie
- Controleren of de tools goed werken in de testomgeving.



Stap 5 Aanval Uitvoeren

- Voer eerste tests uit in een gecontroleerde omgeving.

Stap 6 Resultaten Analyseren

- Bespreken wat goed ging en wat verbeterd kan worden



Vergelijking van methoden/tools die zijn gebruikt (phishing & voorbereiding)

Tijdens de voorbereiding en uitvoering van de aanval zijn verschillende tools ingezet voor het opzetten van de phishingmail en het bouwen van het ransomware-simulatiebestand.

Hieronder een overzicht van relevante tools:

1. Bettercap

Bettercap is een moderne MITM tool die word gebruikt om een range van aanvallen uit te voeren op het gebruikte wifi netwerk en bluetooth netwerk. Bettercap is een open source tool die voornamelijk word gebruikt voor MITM aanvallen, sniffing en het manipuleren van netwerk pakketten.

- Voordelen:
 - Eenvoudig phishingmails en nepsites opzetten.
 - Veel vooraf ingestelde scenario's (bijv. credential harvesting).
 - Ondersteunt e-mailspoofing en templates.
- Nadelen:
 - E-mails kunnen worden geblokkeerd door spamfilters.
 - Minder geschikt voor geavanceerde aanpassingen zonder extra scripts.

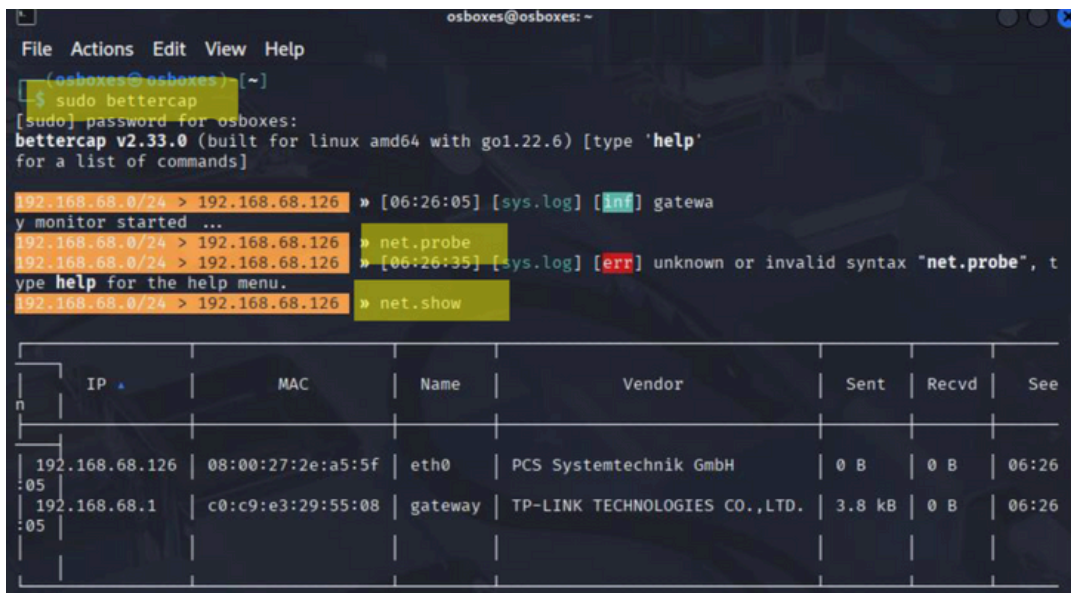
2. Python (voor ransomware simulatie)

Programmeertaal waarmee een eigen .exe ransomware-simulatie is gebouwd.

- Voordelen:
 - Volledige controle over functionaliteit (encryptie, GUI, meldingen).
 - Makkelijk te combineren met GUI-bibliotheken (Tkinter).
 - Kan verbonden worden met een database voor sleuteldistributie.
- Nadelen:
 - Kost tijd om te bouwen en testen.
 - Kan door antivirussoftware als verdacht worden herkend, zelfs als onschadelijk.

Aanvalsstappen gekoppeld aan het PTES-framework

Hieronder volgen de stappen van de aanval, gekoppeld aan de fasen van het PTES-framework (Penetration Testing Execution Standard).



```
osboxes@osboxes: ~  
File Actions Edit View Help  
(osboxes@osboxes) [~]  
$ sudo bettercap  
[sudo] password for osboxes:  
bettercap v2.33.0 (built for linux amd64 with go1.22.6) [type 'help'  
for a list of commands]  
  
192.168.68.0/24 > 192.168.68.126 » [06:26:05] [sys.log] [inf] gatewa  
y monitor started ...  
192.168.68.0/24 > 192.168.68.126 » net.probe  
192.168.68.0/24 > 192.168.68.126 » [06:26:35] [sys.log] [err] unknown or invalid syntax "net.probe", t  
ype help for the help menu.  
192.168.68.0/24 > 192.168.68.126 » net.show  
  
n  
IP      MAC      Name      Vendor      Sent      Recvd      See  
-----  
192.168.68.126 | 08:00:27:2e:a5:5f | eth0 | PCS Systemtechnik GmbH | 0 B | 0 B | 06:26:05  
192.168.68.1 | c0:c9:e3:29:55:08 | gateway | TP-LINK TECHNOLOGIES CO.,LTD. | 3.8 kB | 0 B | 06:26:05
```

1. Voorbereiding van het netwerk

Alle VM's (zoals Kali Linux en doelwit) op hetzelfde wifi-netwerk zitten.

PTES-koppeling: Pre-engagement Interactions

- Deze fase omvat het voorbereiden van de testomgeving en het definiëren van de scope. Hier worden randvoorwaarden gecreëerd voor een ethisch verantwoorde test.

2. Netwerkscan met Bettercap

- Sudo Bettercap: Aan de hand van deze command start je bettercap op. Het kan zijn dat jou VM deze al geïnstalleerd heeft. Mocht dat niet zo zijn kun je dat opzoeken en dan kan je een command om dit te installeren.
 - net.probe on: Dit betekent dat bettercap alle systemen zal scannen die verbonden zijn op hetzelfde netwerk.
 - net.show: Met het vorige command kon je alle systemen scannen. Dit command zorgt ervoor dat alles gelist en gesorteerd word met de bijbehorende informatie.
 - Wanneer je net.show heb gedaan kun je daaruit je slachtoffer vinden om aan te vallen. Daarvoor gebruik je de volgende command.
arp.spoof.targets IP ADD
arp.spoof on
Nu zit jij als mitm tussen de gebruiker en de router in.

PTES-koppeling: Intelligence Gathering

- In deze fase wordt actieve en passieve informatie verzameld over doelwitten. Het helpt de aanvaller begrijpen welke apparaten, services en protocollen beschikbaar zijn.

3. Man-in-the-Middle positioneren (ARP-spoofing)

- Selecteer slachtoffer IP en start spoofing.
 - Wanneer je in bettercap net.show heb gedaan kun je daaruit je slachtoffer vinden om aan te vallen. Daarvoor gebruik je de volgende command. `arp.spoof.targets IP ADD`
`arp.spoof on`
Nu zit jij als mitm tussen de gebruiker en de router in.

PTES-koppeling: Exploitation

- De exploitatie-fase draait om het daadwerkelijk benutten van kwetsbaarheden. Hier wordt via ARP-spoofing toegang verkregen tot netwerkverkeer tussen slachtoffer en router.

4. Website voor redirect opzetten

- Aangepaste website gebouwd met React (frontend) en Node.js (backend), die lokaal draait op het netwerk.
 - De website is ontworpen als malafide imitatie van een legitieme downloadpagina (zoals adobe).

PTES-koppeling: Post-Exploitation (Infrastructure Manipulation)

- Tijdens post-exploitation onderzoekt een aanvaller de mogelijkheden om de aanval te consolideren of uit te breiden. Hier wordt het slachtoffer omgeleid naar een eigen infrastructuur.

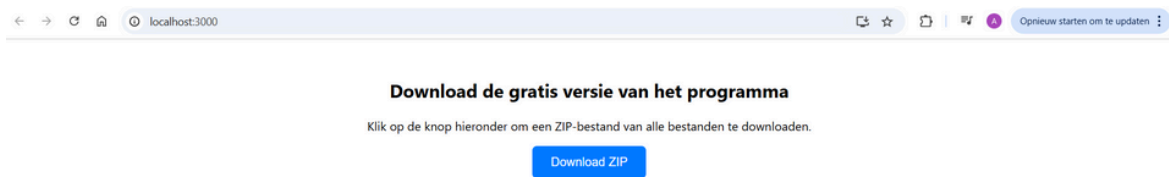
5. DNS-spoofing activeren

- Om nu het slachtoffer te misleiden naar onze eigen website moeten wij het volgende doen. Wij kunnen het volgende command gebruik om ervoor te zorgen dat als de gebruiker voor een download naar bijvoorbeeld adobe.com gaat dat hij dan naar onze site redirect word.
Daarvoor gebruiken we het volgende:
 - `set dns.spoof.domains zoom.com`
 - `dns.spoof on`

Nu zal de gebruiker die volgens onze mail de nieuwste versie moet downloaden op zoom.com terecht op onze eigen website.

PTES-koppeling: Attack Delivery / Initial Access

- In deze PTES-fase wordt de payload geleverd via misleiding. DNS-spoofing zorgt ervoor dat het slachtoffer denkt naar een legitieme site te gaan, maar belandt op een kwaadaardige site.

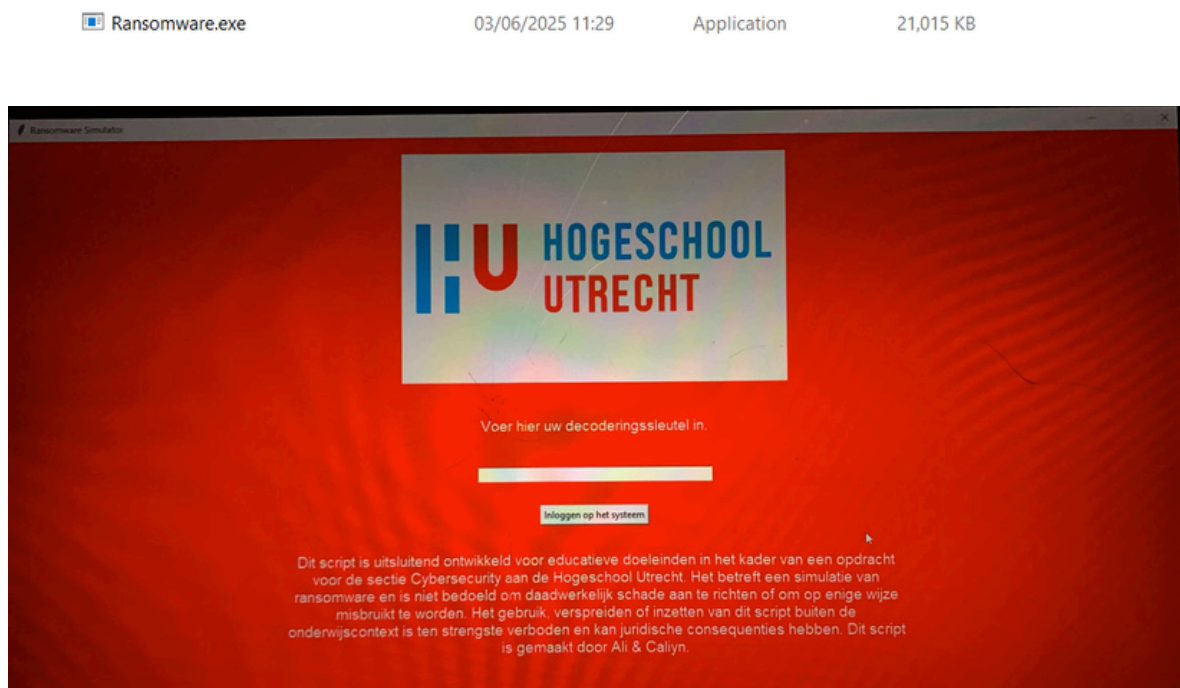


6. Bestandsdownload en uitvoering

- Bij klik op de downloadknop wordt automatisch een ZIP-bestand aangeboden.
 - ZIP bevat een .exe-bestand dat de simulatie van ransomware bevat.
 - Bij uitvoering verschijnt een GUI waarin staat dat bestanden zijn versleuteld.

PTES-koppeling: Exploitation

- Dit is het moment waarop de aanval effectief wordt uitgevoerd. De payload activeert zich, en de ransomware-simulatie toont de impact van een succesvolle aanval.

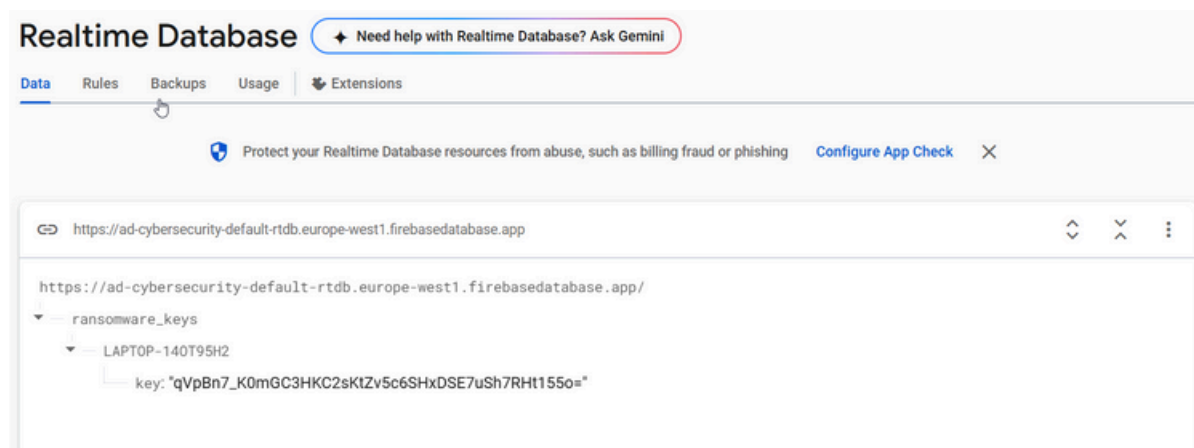
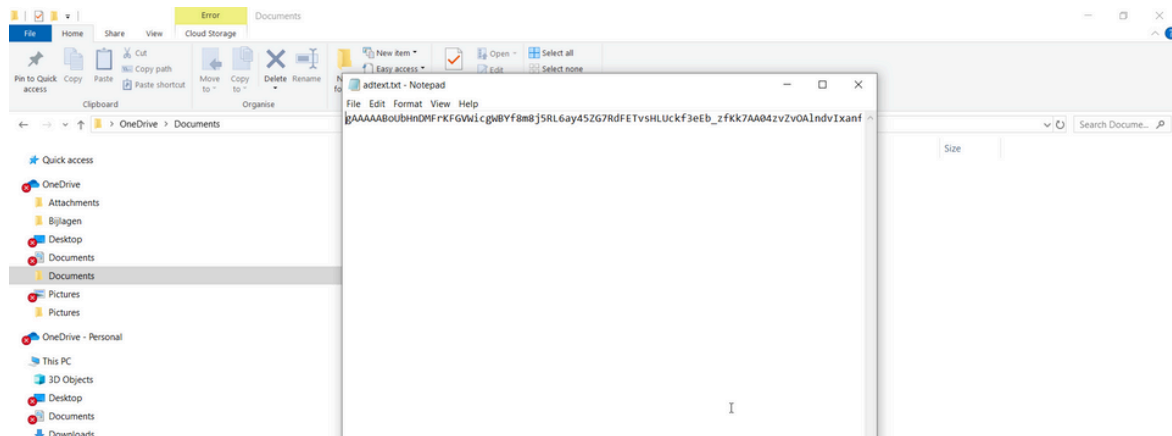


7. Encryptie en gegevensoverdracht

- Bij het uitvoeren van het programma
 - Encryptiesleutel wordt gegenereerd.
 - Sleutel + apparaatnaam worden verzonden naar een realtime database.

PTES-koppeling: Post-Exploitation & Reporting

- In deze fase wordt de impact van de aanval geanalyseerd, en worden gegevens verzameld die later in het rapport worden gebruikt. Dit helpt bij het begrijpen van de volledige reikwijdte van een aanval.



Conclusie

Door deze aanvalsstappen nauwkeurig te volgen en te koppelen aan de PTES-structuur, krijgen we een duidelijk inzicht in hoe een MITM-aanval met phishing en ransomware-simulatie wordt opgebouwd. Elke stap is ontworpen om een realistische, maar gecontroleerde aanval te demonstreren, met ethische waarborgen in acht genomen. Het PTES-framework zorgt ervoor dat elke fase professioneel en reproduceerbaar is uitgevoerd, van voorbereiding tot rapportage.

Algemeen Conclusie

Ransomware en Man-in-the-Middle (MitM) aanvallen zijn twee gevaarlijke manieren waarop hackers systemen kunnen aanvallen. Bij ransomware worden bestanden geblokkeerd en moet losgeld worden betaald om ze terug te krijgen. Bij MitM kijkt de aanvaller stiekem mee of verandert informatie terwijl er gedacht wordt veilig te communiceren. Beide aanvallen kunnen de veiligheid van informatie ernstig aantasten.

Om deze aanvallen te voorkomen, zijn zaken zoals back-ups maken, sterke wachtwoorden, 2-stapsverificatie en het gebruik van een VPN heel belangrijk.

Door deze aanvallen zelf na te bootsen in een veilige testomgeving, is veel geleerd over hoe ze werken en hoe bescherming kan worden geboden.

Er is daarbij het PTES-framework gevolgd. Dat is een stappenplan voor hoe een aanval op een professionele en veilige manier getest kan worden.

Bronnenlijst

- Wikipedia
 - <https://en.wikipedia.org/wiki/Ransomware>
 - https://en.wikipedia.org/wiki/Man-in-the-middle_attack
- <https://www.kpn.com/zakelijk/thedigitaldutch/blog/man-in-the-middle-aanval>
- Wetenschappelijke Publicaties
 - "A Review of Man-in-the-Middle Attacks" – Subodh Gangan
<https://arxiv.org/abs/1504.02115>
- <https://www.morningstar.com/news/business-wire/20250410139431/at-bay-remote-access-tools-behind-4-of-5-ransomware-attacks-in-2024-supply-chain-driven-cyber-claims-up-43>
- https://www.wired.com/story/black-basta-ransomware-gang/?utm_source=chatgpt.com
- How Does Ransomware Work? – A Step-by-Step Breakdown
 - https://youtu.be/Q_ZFvfDSill?si=tdy2oRfHX3QrUq4I
- Man-in-the-Middle Attack 40 Minutes Practical Tutorial | Step-by-Step Ethical Hacking
 - https://youtu.be/pk2OtnJV7xE?si=H_JEY4ZEBJw-pGI3